



(Not So) Secret Tunnel: Digging into Exposed ngrok Endpoints

Eugene Lim @spaceraccoon

whoami

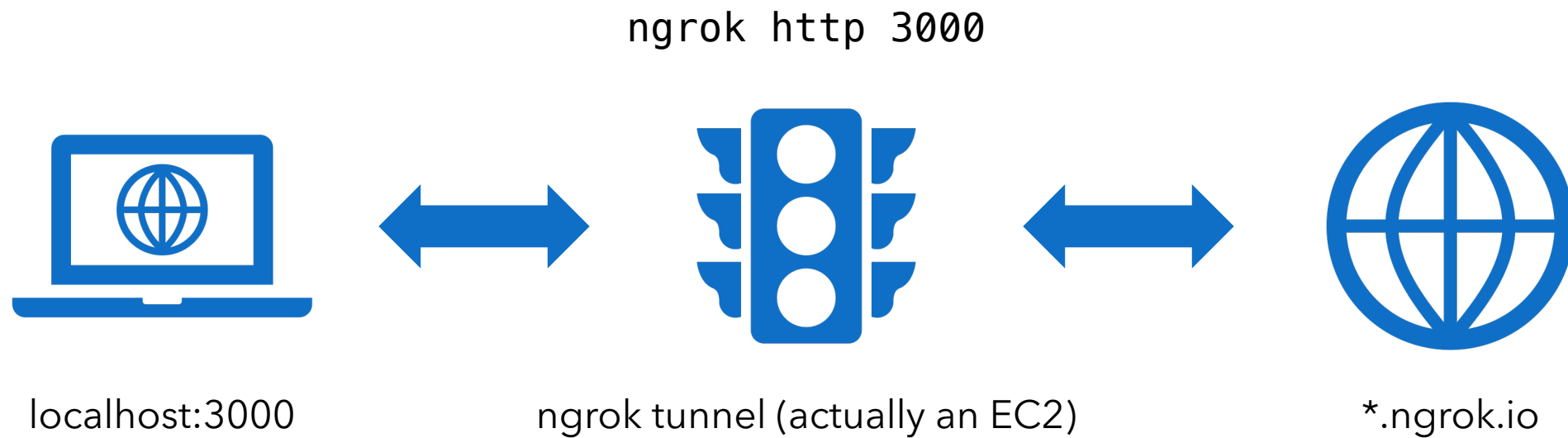
Eugene Lim

@spaceraccoon

Cybersecurity Group,
GovTech Singapore



Developers use ngrok to quickly scaffold applications on the web.



Do you
need a
public
URL in
dev?

Create subscription

Details

Topic ARN



arn:aws:sns:us-east-1:1337:Hax



Protocol

The type of endpoint to subscribe

HTTPS



Endpoint

A web server that can receive notifications from Amazon SNS.

https://localhost

☐ Enable raw message delivery



After your subscription is created, you must confirm it. [Info](#)

A close-up photograph of a red pushpin stuck into a map. The pushpin is in sharp focus, while the map and other pins in the background are blurred. The map shows various lines and colors, suggesting a geographical or network diagram.

ngrok uses several URL formats depending on protocol and region.

`https://5e9c5373ffed.ngrok.io`

`https://4585-186-3-179-208.ngrok.io`

`https://customname.ngrok.io`

`6.tcp.ngrok.io:13371`

context:globalhttps://[a-zA-Z0-9\-\+]\.ngrok.io

Aa

 []

REPOSITORIES

Find...

- r:  microsoft/BotBuilder-S 247
amples
- r:  redwoodjs/redwood 30
- r:  bottenderjs/messaging-a 24
pis
- r:  mastodon/mastodon 24
- r:  slackapi/bolt-js 14
- r:  slackapi/node-slack-sdk 14

SEARCH REFERENCE

Find...

Common All filters Operators

- type:diff/commit/...
- repo:regexp-pattern
- rev:revision
- file:regexp
- lang:language-name
- select:result-types
- count:N/all
- content:"pattern"
- fork:yes/or
- after:"last week"

Search syntax

SEARCH SNIPPETS

reDEF CON 30 Recon Village

search all branches

```
86 expect(url).toBe('https://a062-174-94-6-155.ngrok.io/report/jquery.min.js');
87 };
```

 mastodon/mastodon > spec/requests/link_headers_spec.rb 1 match

```
22
23 expect(link_header.href).to eq 'https://cb6e6126.ngrok.io/users/test'
24 expect(link_header.attr_pairs.first).to eq %w(rel alternate)
```

 mastodon/mastodon > spec/controllers/concerns/account_controller_concern_spec.rb 1 match

```
66 get 'success', params: { account_username: 'username' }
67 expect(response.headers['Link']).to eq '<http://test.host/.well-known/webfinger?resource=acct%3Ausername%40cb6e6126.ngrok.io>; rel="lrdd"; type="application/jrd+json"'
68 end
```

 mastodon/mastodon > spec/controllers/well_known/host_meta_controller_spec.rb 1 match

```
14 <XRD xmlns="http://docs.oasis-open.org/ns/xri/xrd-1.0">
15   <Link rel="lrdd" template="https://cb6e6126.ngrok.io/.well-known/webfinger?resource={uri}"/>
16 </XRD>
```

 mastodon/mastodon > spec/mailers/admin_mailer_spec.rb 1 match

```
22 it 'renders the body' do
23   expect(rendered_body).to eq "Mike\r\n\r\nView: https://cb6e6126.ngrok.io/admin/reports/#{report.id}\r\n"
24 end
```

 mastodon/mastodon > spec/lib/permalink_redirector_spec.rb 4 matches

```
18 redirector = described_class.new('web/statuses/123')
19 expect(redirector.redirect_path).to eq 'https://cb6e6126.ngrok.io/@alice/123'
20 end
```

```
28 redirector = described_class.new('web/@alice')
29 expect(redirector.redirect_path).to eq 'https://cb6e6126.ngrok.io/@alice'
30 end
```

```
33 redirector = described_class.new('web/@alice/123')
34 expect(redirector.redirect_path).to eq 'https://cb6e6126.ngrok.io/@alice/123'
```

Devs leave ngrok artifacts in code...

Web hooks are a common use- case.

```
var notifications =  
Notification.getAll()  
  
axios.post('https://mytempwebhook.ngrok.  
io', {  
    notifications: notifications  
}).then(function (response) {  
    console.log(response);  
}).catch(function (error) {  
    console.log(error);  
});
```

NAME:

http - start an HTTP tunnel

USAGE:

ngrok http [address:port | port] [flags]

DESCRIPTION:

Starts a tunnel listening for HTTP/HTTPS traffic with a specific hostname. The HTTP Host header on incoming public requests is inspected to determine which tunnel it matches.

HTTPS endpoints terminate TLS traffic at the ngrok server using the appropriate certificates. The decrypted, HTTP traffic is then forwarded through the secure tunnel and then to your local server. If you don't want your TLS traffic to terminate at the ngrok server, use a TLS or TCP tunnel.

TERMS OF SERVICE: <https://ngrok.com/tos>

EXAMPLES:

```
ngrok http 8080 # forward ngrok.io subdomain to port 80
ngrok http --subdomain=example.com 8080 # forward traffic to example.com:8080
ngrok http --subdomain=bar 80 # request subdomain name: 'bar.ngrok.io'
ngrok http --hostname=ex.com 1234 # request tunnel: ex.com (DNS CNAME)
ngrok http --basic-auth='falken:joshua' 80 # enforce basic auth on tunnel endpoint
ngrok http --host-header=ex.com 80 # rewrite the Host header to 'ex.com'
ngrok http file:///var/log # serve local files in /var/log
ngrok http https://localhost:8443 # forward to a local https server
```

OPTIONS:

--authtoken string	ngrok.com authtoken identifying a user
--basic-auth strings	enforce basic auth on tunnel endpoint, 'user:password'

Paid users can set custom ngrok subdomains...

Squatting domains can lead to info leaks or even injection.

ngrok online [InspectStatus](#) [Documentation](#)

Filter by

All Requests Clear Requests

GET /webhook	502 Bad Gateway	0.88ms
--------------	-----------------	--------

about 4 hours ago Duration 0.88ms IP 3.88.14.211

GET /webhook

Summary Headers Raw Binary Replay

Headers

Accept-Encoding	gzip
Host	your-domain.ngrok.io
User-Agent	Go-http-client/2.0
X-Forwarded-For	3.88.14.211
X-Forwarded-Proto	https

502 Bad Gateway

Summary Headers Raw Binary

39037 bytes text/html

```
<!doctype html>
<html>
<head>
  <style type="text/css">
    [class^="ant-"]::-ms-clear,
    [class*="ant-"]::-ms-clear {
      display: none;
    }
    [class^="ant-"],
    [class*="ant-"],
    [class^="ant-"] *,
    [class*="ant-"] *,
    [class^="ant-"] ::before,
    [class*="ant-"] ::before,
    [class^="ant-"] ::after,
    [class*="ant-"] ::after {
      box-sizing: border-box;
    }
  </style>
  html,
  body {
    width: 100%;
    height: 100%;
  }
  *,
  ::before,
  ::after {
    box-sizing: border-box;
  }
  html {
```

Domains

Create a domain to accept HTTP, HTTPS and TLS traffic. You may create subdomains of our `ngrok.io` base domain or bring your own domain name via the creation of a CNAME DNS record. Domains will never be assigned to another account, even if any backing tunnels are offline.

[API Docs](#)[+ New Domain](#)

ID	Region	Domain	Description	TLS	Status	Created
rd...16CT9e	SA	company.sa.ngrok.io		*.ngrok.io		2mo ago
rd...boPY89	EU	app.eu.ngrok.io	webhook testing	*.ngrok.io		2w ago
rd...ffESsG	JP	*.dev.company.com	developer tunnels	cert...FcnXjt		1d ago
rd...o6b1jY	US	kiosk-1.devices.company.com	device at location 12	Provisioning		4w ago

ngrok allows paid users to reserve domains without much verification.

A close-up photograph of a red pushpin stuck into a map. The map shows various colored lines and text, but it is out of focus. In the background, a blue pushpin and a yellow pushpin are also visible, also out of focus.

ngrok uses several URL formats depending on protocol and region.

`https://5e9c5373ffed.ngrok.io`

`https://4585-186-3-179-208.ngrok.io`

`https://customname.ngrok.io`

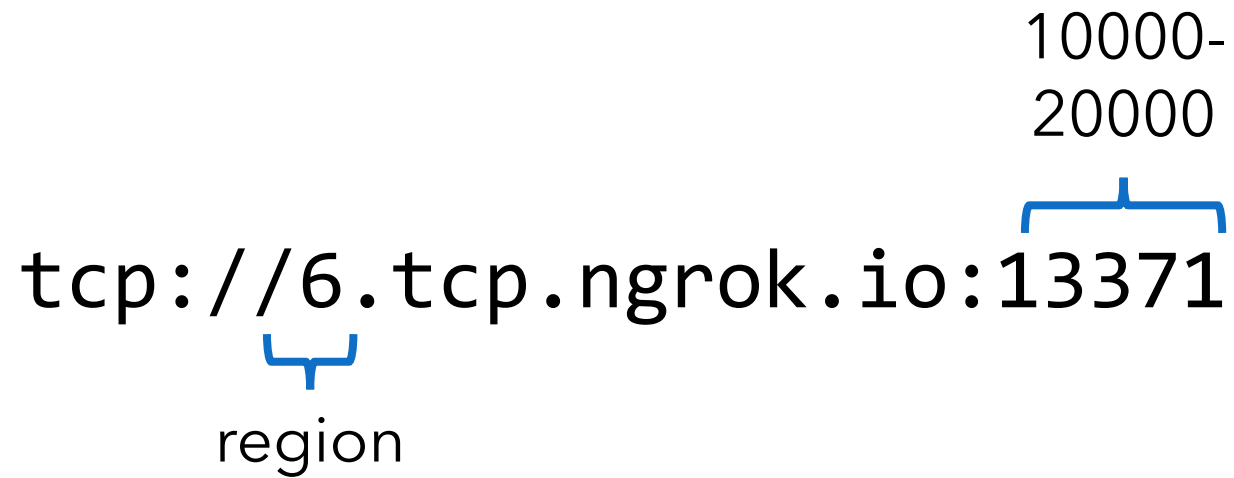
`6.tcp.ngrok.io:13371`

The TCP domain is easily enumerable.

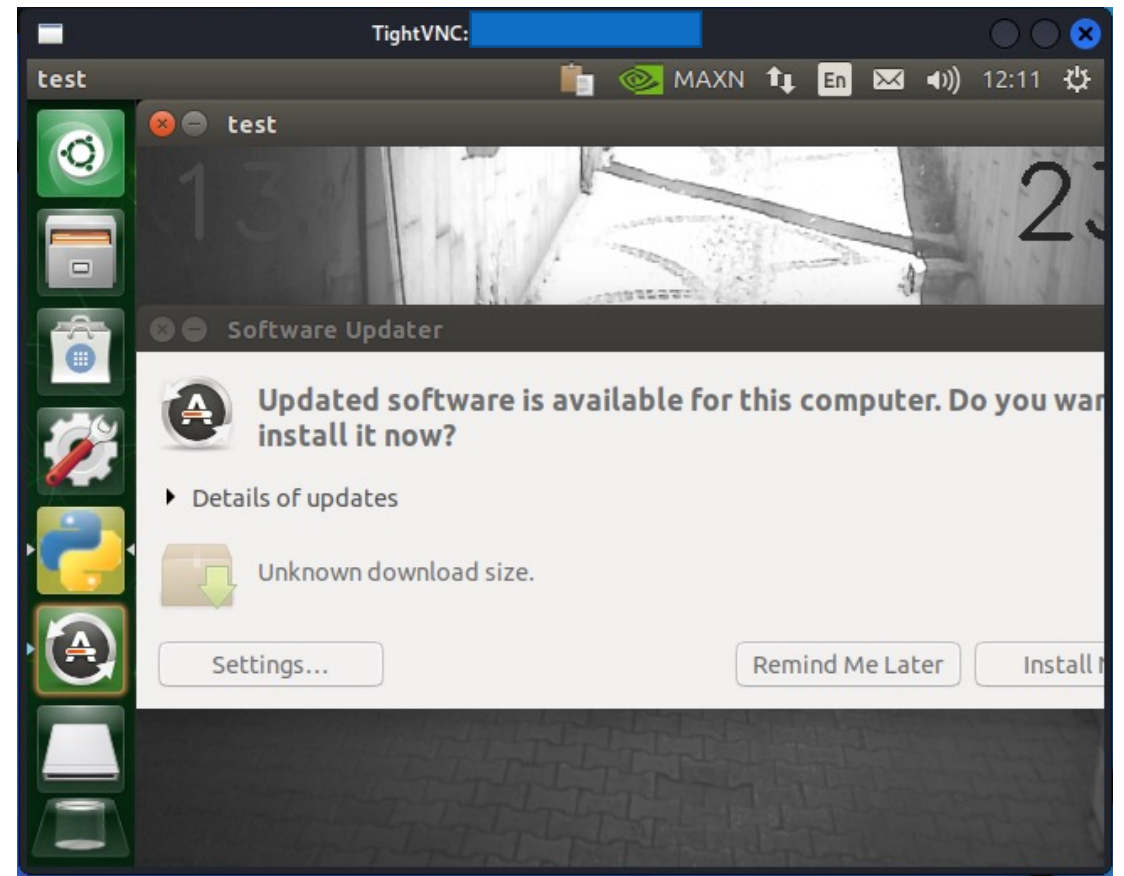
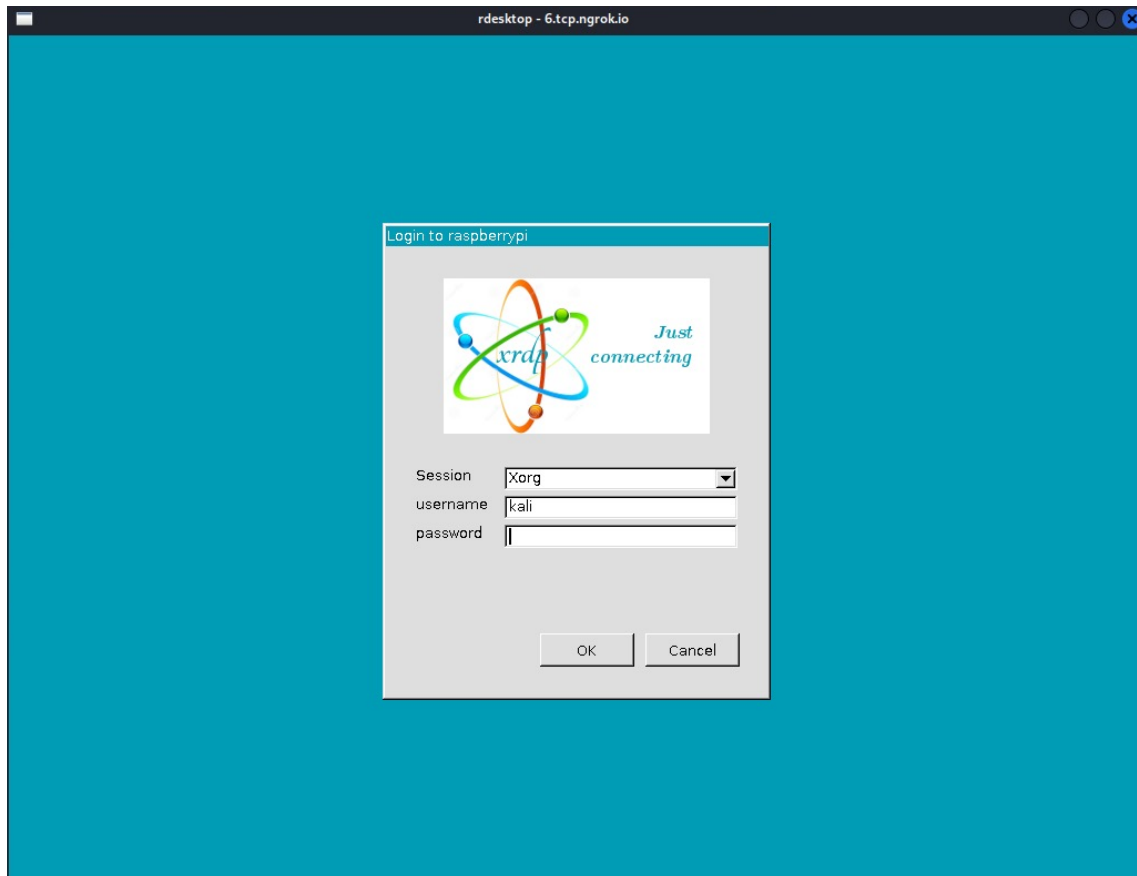
10000-
20000

tcp://6.tcp.ngrok.io:13371

region



RDP/VNC servers ☹️



Databases ☹️

```
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 23886468
Server version: 5.6.32-78.1-log Source distribution

Copyright (c) 2000, 2022, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

[mysql> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| test       |
+-----+
2 rows in set (0.35 sec)

mysql> █
```

Various web servers ☹️

PLEX



Welcome to Jenkins!

Sign in

☐ Keep me signed in

Burp Suite Professional

Welcome to Burp Suite Professional.



XAMPP Apache + MariaDB + PHP + Perl

Welcome to XAMPP for Windows 5.6.19

PHP Version 5.6.19



(AMPP on this system! Now you can start using Apache, MariaDB, PHP and other components. You can check the [HOW-TO Guides](#) for getting started with PHP applications.

o check the server status.

System	Windows NT EKLAIM 6.1 build 7601 (Windows 7 Ultimate Edition Service Pack 1) i586
Build Date	Mar 2 2016 20:00:17
Compiler	MSVC11 (Visual C++ 2012)
Architecture	x86

XAMPP has been around for more than 10 years – there is a huge community behind it. You can get involved by joining our [Forums](#), adding yourself to the [Mailing List](#), and liking us on [Facebook](#), following our exploits on [Twitter](#), or adding us to your [Google+](#) circles.

Contribute to XAMPP translation at translate.apachefriends.org.

Can you help translate XAMPP for other community members? We need your help to translate XAMPP into different languages. We have set up a site, translate.apachefriends.org, where users can contribute translations.

Install applications on XAMPP using Bitnami

Apache Friends and Bitnami are cooperating to make dozens of open source applications available on XAMPP, for free. Bitnami-

Directory listing for /

- [ReverseShell.class](#)
- [ReverseShell.java](#)

ngrok presents two recon surfaces.



Outside-In

- Exposed services
- Known domain permutations

Inside-Out

- Codebases
- Domain squatting
- Subdomain domain

Summary

Dev tools like ngrok bridge the private/public network separation boundary for certain use cases but expose a new attack surface. Orgs should closely monitor the use of these tools especially in open-source code.



Thank you

Eugene Lim

@spaceracconsec

spaceraccoon.dev

